Compliance Annotation

Clearwater Regional Medical Center

Framework: HIPAA | Compliance Level: Fully Compliant

Finding 1: [COMPLIANT] Mandatory HIPAA Header and Statement of Purpose

The notice prominently displays the required "This notice describes how medical information about you may be used..." header. It explicitly acknowledges the facility's legal duty to maintain the privacy and security of PHI.

References: 45 CFR 164.520(b)(1)(i)

Finding 2: [COMPLIANT] Access and Amendment Rights with Regulatory Timelines

Clearwater specifies the correct regulatory response windows: 30 days for medical record access (including electronic formats) and 60 days for a written response to amendment requests. This exceeds general summaries by binding the provider to specific HIPAA timelines.

References: 45 CFR 164.524, 45 CFR 164.526

Finding 3: [COMPLIANT] Mandatory Out-of-Pocket Restriction Requirement

The policy correctly identifies the HITECH-mandated exception where the entity must agree to a restriction if the patient pays for a service in full out-of-pocket and requests the information not be shared with their health plan.

References: 45 CFR 164.522(a)(1)(vi)

Finding 4: [COMPLIANT] Accounting of Disclosures and Communications

The notice provides for a six-year look-back period for accountings of disclosures and outlines the right to confidential communications (e.g., alternate locations or methods), meeting the standard for patient control.

References: 45 CFR 164.528, 45 CFR 164.522(b)

Finding 5: [COMPLIANT] Treatment, Payment, and Healthcare Operations (TPO)

The policy clearly defines TPO uses with concrete examples (e.g., consultation between physicians, billing health plans, medical student training), satisfying the requirement for descriptive transparency.

References: 45 CFR 164.520(b)(1)(ii)

Finding 6: [COMPLIANT] Authorization for Psychotherapy Notes, Sale, and Marketing

Clearwater explicitly states that written authorization is required for the most common high-risk disclosures, including marketing, the sale of PHI, and psychotherapy notes, while noting the patient's right to revoke such authorization.

References: 45 CFR 164.508, 45 CFR 164.520(b)(1)(ii)(E)

Finding 7: [COMPLIANT] Opportunity to Object (Directory and Family Disclosures)

The policy describes "Choices" regarding the hospital directory and sharing info with family/friends involved in care, including the procedure for when a patient is incapacitated, aligning with standards for informal consent.

References: 45 CFR 164.510

Finding 8: [COMPLIANT] Fundraising Opt-Out Requirements

The notice identifies that PHI may be used for fundraising but provides a clear right for the patient to opt out of such communications.

References: 45 CFR 164.514(f)

Finding 9: [COMPLIANT] Public Interest and Benefit Disclosures

The policy enumerates permitted disclosures without authorization, including public health reporting, abuse/neglect investigations, law enforcement, and research approved by an Institutional Review Board (IRB).

References: 45 CFR 164.512

Finding 10: [COMPLIANT] Breach Notification Integrity

The commitment to notify patients within 60 days of discovery is clearly stated. Crucially, the policy lists the specific required elements of the notice (description of breach, types of info, mitigation steps), which is a stricter requirement than simple notification acknowledgement.

References: 45 CFR 164.404

Finding 11: [COMPLIANT] Business Associate Agreement (BAA) Oversight

The policy acknowledges that third-party contractors (transcription, IT) must enter into BAAs that obligate them to follow the minimum necessary standard and report breaches back to the covered entity.

References: 45 CFR 164.504(e), 45 CFR 164.502(b)

Finding 12: [COMPLIANT] Minimum Necessary Standard Application

The provider commits to the minimum necessary standard for all uses, disclosures, and requests for PHI, satisfying the core HIPAA administrative requirement.

References: 45 CFR 164.502(b), 45 CFR 164.514(d)

Finding 13: [COMPLIANT] Formal Complaint Process and Non-Retaliation

The notice provides clear contact information for the hospital's Privacy Officer and the HHS Office for Civil Rights (OCR), including a phone number and website, and explicitly guarantees no retaliation for filing a complaint.

References: 45 CFR 164.520(b)(1)(vi)

Finding 14: [COMPLIANT] Contact Information and Notice Effectiveness

The policy lists a named Privacy Officer (Sarah Mitchell, JD, CHPC) with full credentials and contact data, and specifies an effective date, ensuring the notice is properly authenticated.

References: 45 CFR 164.520(b)(1)(vii)